

RAPPORT DE SÉCURITÉ

ORTHRUS

Rapport de Tests d'Intrusion API

Cible:

<https://petstore3.swagger.io/api/v3/openapi.json>

Date du Scan: 2026-06-04 11:03:15

Avertissement Légal & Confidentialité

Ce rapport est STRICTEMENT CONFIDENTIEL et sa distribution est soumise à restriction. Il est destiné uniquement au personnel autorisé. Il est généré par un outil automatisé de test de sécurité (Orthrus). L'outil assigne un score CVSS de Base théorique qui peut ne pas refléter le contexte environnemental ou temporel de la vulnérabilité. Les auteurs et l'outil lui-même déclinent toute responsabilité en cas de vulnérabilité non détectée, de failles critiques manquées, ou de compromissions ultérieures des systèmes testés. Cet outil est fourni exclusivement pour des tests de sécurité autorisés et encadrés.

Méthodologie et Critères d'Évaluation

Ce rapport présente les résultats d'une analyse automatisée de sécurité dynamique (DAST). L'analyse a consisté à envoyer divers payloads malveillants et des entrées inattendues à l'API cible afin d'identifier les vulnérabilités de sécurité.

Méthodologies et Standards

Standard	Application
OWASP API Security Top 10	Classification des vulnérabilités spécifiques aux API et directives de test
OWASP Top 10 (2021)	Framework principal de classification des vulnérabilités web
CVSS v3.1	Système commun d'évaluation des vulnérabilités pour une notation objective de la criticité
CWE / CAPEC	Énumération des faiblesses communes et suivi des modèles d'attaque
Évaluation DAST Automatisée	Injection dynamique de payloads, fuzzing et évaluation des états authentifiés/non-authentifiés

Définition de la Note de Sécurité

- A** Excellente posture de sécurité. Aucune vulnérabilité élevée ou critique détectée.
- B** Bonne posture de sécurité. Des vulnérabilités mineures sont présentes, mais aucune menace critique immédiate.
- C** Posture de sécurité passable. Plusieurs vulnérabilités moyennes ou une seule vulnérabilité élevée nécessitent une attention particulière.
- D** Médiocre posture de sécurité. Plusieurs vulnérabilités élevées détectées. Une correction urgente est nécessaire.
- F** Échec critique. Une ou plusieurs vulnérabilités critiques détectées, exposant l'application à des risques immédiats et sévères.

1. Résumé Global

NOTE GLOBALE DE RISQUE

F

STATISTIQUES CLÉS

143

TOTAL DES VULNÉRABILITÉS

8

CRITIQUE

4

ÉLEVÉ

36

MOYEN

95

FAIBLE

0

INFO

CRITIQUE: Les vulnérabilités critiques indiquent une menace grave et immédiate pour la sécurité de l'application. Elles peuvent généralement être exploitées sans authentification et entraîner une compromission totale du système ou une fuite de données majeure. Une correction immédiate est requise.

ÉLEVÉ: Les vulnérabilités de niveau élevé représentent une menace significative. Elles nécessitent souvent un certain niveau d'accès ou une exploitation complexe, mais peuvent entraîner un vol de données majeur ou une perturbation du système. Elles doivent être traitées en priorité haute.

MOYEN: Les vulnérabilités moyennes représentent une menace modérée. Elles nécessitent généralement des conditions préalables spécifiques ou un accès autorisé pour être exploitées. Elles doivent être corrigées lors de la prochaine mise à jour.

FAIBLE: Les vulnérabilités faibles ont un impact minime. Elles peuvent exposer des informations non sensibles ou nécessiter des scénarios très improbables pour être exploitées. Elles doivent être traitées lorsque les ressources le permettent.

INFO: Les observations informatives ne représentent pas une vulnérabilité directe, mais soulignent des bonnes pratiques de sécurité qui pourraient être améliorées pour renforcer la posture globale.

2. Résumé des Vulnérabilités

Chaque découverte est notée sous CVSS v3.1 (pour la parité avec NVD, CISA KEV et la plupart des avis des fournisseurs) et CVSS v4.0 (norme FIRST actuelle depuis novembre 2023). Les bandes de sévérité sont identiques pour les deux versions. Les entrées détaillées incluent les vecteurs complets v3.1 et v4.0. Les scores reflètent ce qui a été enregistré lors de l'évaluation initiale ; les vecteurs sont documentés pour la reproductibilité par rapport au calculateur CVSS du FIRST.

Distribution des Sévérités

Sévérité	Nombre	Plage CVSS (v3.1 / v4.0)	Priorité de Correction
CRITIQUE	8	9.0 to 10.0	Immédiate (avant la prochaine version)
ÉLEVÉ	4	7.0 to 8.9	Dans 1 cycle de sprint
MOYEN	36	4.0 to 6.9	Dans 2 cycles de sprint
FAIBLE	95	0.1 to 3.9	Prochaine revue trimestrielle
INFO	0	0.0	Recommandation de bonne pratique

3. Résultats Détaillés

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_306

9.8

Référence CAPEC: CAPEC-115

OWASP: A07:2025 - Authentication Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

No Response

Remédiation

Implement robust authentication for this endpoint.

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_306

9.8

Référence CAPEC: CAPEC-115

OWASP: A07:2025 - Authentication Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Implement robust authentication for this endpoint.

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_306

9.8

Référence CAPEC: CAPEC-115

OWASP: A07:2025 - Authentication Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/store/order`

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Implement robust authentication for this endpoint.

Time-Based Blind SQL Injection

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_89

9.8

Référence CAPEC: CAPEC-66

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The endpoint took 4843ms to respond, indicating a potential Time-Based Blind SQL Injection in parameter 'tags'.

Preuve

Response was delayed by 4843ms when payload " OR '1'='1' was injected.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByTags?tags=' OR '1'='1'
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 2
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)
```

```
[]
```

Remédiation

Use parameterized queries or prepared statements.

Time-Based Blind SQL Injection

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_89

9.8

Référence CAPEC: CAPEC-66

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint took 4846ms to respond, indicating a potential Time-Based Blind SQL Injection in parameter 'status'.

Preuve

Response was delayed by 4846ms when payload " OR '1'='1' was injected.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=' OR '1'='1'
```

Réponse :

```
Status: 400 BAD_REQUEST
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 141
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"code":400,"message":"Input error: query parameter `status` value `` OR '1'='1` is not in the allowable values `[available, pending, sold]`"}
```

Remédiation

Use parameterized queries or prepared statements.

Time-Based Blind SQL Injection

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_89

9.8

Référence CAPEC: CAPEC-66

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The endpoint took 4903ms to respond, indicating a potential Time-Based Blind SQL Injection in parameter 'additionalMetadata'.

Preuve

Response was delayed by 4903ms when payload " OR '1'='1' was injected.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=' OR '1'='1'
```

Réponse :

```
Status: 400 BAD_REQUEST
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 16
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)
```

No file uploaded

Remédiation

Use parameterized queries or prepared statements.

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_306

9.8

Référence CAPEC: CAPEC-115

OWASP: A07:2025 - Authentication Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

No Response

Remédiation

Implement robust authentication for this endpoint.

Time-Based Blind SQL Injection

Sévérité:

CRITIQUE

Score CVSS de Base: CWE: CWE_89

9.8

Référence CAPEC: CAPEC-66

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint took 4910ms to respond, indicating a potential Time-Based Blind SQL Injection in parameter 'name'.

Preuve

Response was delayed by 4910ms when payload " OR '1'='1' was injected.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=' OR '1'='1&status=laudantium
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 77
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"' OR '1'='1","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Use parameterized queries or prepared statements.

Potential Broken Function Level Authorization

Sévérité:

ÉLEVÉ

Score CVSS de Base: CWE: CWE_285

9.8

Référence CAPEC: CAPEC-115

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint accepts administrative HTTP methods (like DELETE) even though it was discovered as a GET endpoint. Verify if the current user should have this privilege.

Preuve

Server returned 200 OK OK when sending a DELETE request to a GET endpoint.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/30
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 11
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

Pet deleted
```

Remédiation

Ensure function-level access control checks exist for all administrative operations and methods.

Unrestricted File Upload

Sévérité:

ÉLEVÉ

Score CVSS de Base: CWE: CWE_434

8.8

Référence CAPEC: CAPEC-17

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint allowed the upload of an executable or potentially dangerous file (EICAR test string) without blocking it.

Preuve

Server responded with 200 OK OK after uploading an EICAR test file.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
Content-Type: multipart/form-data; boundary=---WebKitFormBoundary7MA4YWxkTrZu0gW

-----WebKitFormBoundary7MA4YWxkTrZu0gW
Content-Disposition: form-data; name="file"; filename="eicar.com"
Content-Type: application/x-msdownload

X50!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*
-----WebKitFormBoundary7MA4YWxkTrZu0gW--
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Implement strict file type validation (using magic bytes, not just extensions). Use an antivirus scanner on all uploaded files. Store files outside the web root.

Potential HTTP Request Smuggling (TE.TE / CL.TE)

Sévérité:

ÉLEVÉ

Score CVSS de Base: CWE: CWE_444

7.5

Référence CAPEC: CAPEC-33, CAPEC-272

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

FALSE POSITIVES LIKELY: Manual testing required! The server accepted an ambiguous Transfer-Encoding header without returning a 400 Bad Request. If this server sits behind a proxy or load balancer, it might be vulnerable to HTTP Request Smuggling.

Preuve

Server responded with 200 OK instead of 400 when sending a malformed Transfer-Encoding header.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
Transfer-Encoding: chunked, cow
```

```
0
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Ensure the frontend proxy and backend server interpret the Transfer-Encoding and Content-Length headers consistently. Reject requests with ambiguous or duplicated headers. Prefer using HTTP/2.

Potential Broken Function Level Authorization

Sévérité:

ÉLEVÉ

Score CVSS de Base: CWE: CWE_285

9.8

Référence CAPEC: CAPEC-115

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **GET** <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint accepts administrative HTTP methods (like DELETE) even though it was discovered as a GET endpoint. Verify if the current user should have this privilege.

Preuve

Server returned 200 OK OK when sending a DELETE request to a GET endpoint.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/26
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:24 GMT
Content-Length: 0
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)
```

Remédiation

Ensure function-level access control checks exist for all administrative operations and methods.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_639

7.5

Référence CAPEC: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 30 to 31. Ensure the authenticated user has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 31

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/31
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 80
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":31,"name":"motherhoods","photoUrls":[],"tags":[],"status":"Buddy Updated"}
```

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_639

7.5

Référence CAPEC: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 30 to 29. Ensure the authenticated user has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 29

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/29
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 75
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":29,"name":"GoldenRetriever","photoUrls":[],"tags":[],"status":"sold"}
```

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_352

6.5

Référence CAPEC: CAPEC-62

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with Origin: <https://malicious-website.com> and no CSRF tokens.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
Origin: https://malicious-website.com
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_639

7.5

Référence CAPEC: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 45 to 44. Ensure the authenticated user has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 44

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/44?name=minus&status=laudantium
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":44,"name":"minus","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_352

6.5

Référence CAPEC: CAPEC-62

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with Origin: <https://malicious-website.com> and no CSRF tokens.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
Origin: https://malicious-website.com
api_key: minima
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 11
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

Pet deleted
```

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_352

6.5

Référence CAPEC: CAPEC-62

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/store/order`

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with Origin: `https://malicious-website.com` and no CSRF tokens.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Origin: https://malicious-website.com
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 48
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":0,"petId":0,"quantity":0,"complete":false}
```

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Potential Mass Assignment (BOPLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_915

6.5

Référence CAPEC: CAPEC-17

OWASP: A08:2025 - Software or Data Integrity Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint accepts unexpected fields (e.g., 'is_admin', 'role') in the JSON payload without returning a validation error.

Preuve

Server returned 200 OK OK after injecting privilege escalation fields into the JSON payload.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
```

```
Content-Type: application/json
```

```
{"data":"repudiandae","is_admin":true,"isAdmin":true,"role":"admin","permissions":"all"}
```

Réponse :

```
Status: 200 OK
```

```
Date: Thu, 04 Jun 2026 09:03:22 GMT
```

```
Content-Type: application/json
```

```
Content-Length: 48
```

```
Connection: keep-alive
```

```
Access-Control-Allow-Origin: *
```

```
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
```

```
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
```

```
Access-Control-Expose-Headers: Content-Disposition
```

```
Server: Jetty(9.4.53.v20231009)
```

```
{"id":0,"petId":0,"quantity":0,"complete":false}
```

Remédiation

Use DTOs (Data Transfer Objects) to explicitly map accepted fields. Avoid binding HTTP requests directly to domain models or database entities.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_639

7.5

Référence CAPEC: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 64 to 65. Ensure the authenticated user has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 65

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/65
api_key: minima
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 11
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

Pet deleted
```

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_639

7.5

Référence CAPEC: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 64 to 63. Ensure the authenticated user has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 63

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/63
api_key: minima
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 11
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

Pet deleted
```

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_639

7.5

Référence CAPEC: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint returned a successful response when the resource ID was modified from 26 to 25. Ensure the authenticated user has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 25

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/order/25
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:24 GMT
Content-Type: application/json
Content-Length: 110
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":25,"petId":5,"quantity":3,"shipDate":"2026-06-03T22:20:25.714+00:00","status":"placed","complete":false}
```

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_352

6.5

Référence CAPEC: CAPEC-62

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with Origin: <https://malicious-website.com> and no CSRF tokens.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
Origin: https://malicious-website.com
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:24 GMT
Content-Length: 0
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)
```

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **GET** <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=<script>alert('XSS_VULNAPI_TEST')</script>
```

Réponse :

```
Status: 400 BAD_REQUEST
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 172
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"code":400,"message":"Input error: query parameter `status` value `<script>alert('XSS_VULNAPI_TEST')</script>` is not in the allowable values `[available, pending, sold]`"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status="><script>alert(1)</script>
```

Réponse :

```
Status: 400 BAD_REQUEST
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 158
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"code":400,"message":"Input error: query parameter `status` value `\"><script>alert(1)</script>` is not in the allowable values `[available, pending, sold]`"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status="><img src=x onerror=alert(1)>
```

Réponse :

```
Status: 400 BAD_REQUEST
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 161
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"code":400,"message":"Input error: query parameter `status` value `\"><img src=x onerror=alert(1)>` is not in the allowable values `[available, pending, sold]`"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=</script><svg/onload=alert(1)>
```

Réponse :

```
Status: 400 BAD_REQUEST
Date: Thu, 04 Jun 2026 09:03:23 GMT
Content-Type: application/json
Content-Length: 160
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"code":400,"message":"Input error: query parameter `status` value `</script><svg/onload=alert(1)>` is not in the allowable values `[available, pending, sold]`"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'name' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=<script>alert('XSS_VULNAPI_TEST')</script>&status=laudantium
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 108
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"<script>alert('XSS_VULNAPI_TEST')</script>","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'name' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name="><script>alert(1)</script>&status=laudantium
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 94
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"><script>alert(1)</script>","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'name' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name="><img src=x onerror=alert(1)
>&status=laudantium
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:22 GMT
Content-Type: application/json
Content-Length: 97
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"><img src=x onerror=alert(1)>","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'name' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=</script><svg/onload=alert(1)
>&status=laudantium
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:23 GMT
Content-Type: application/json
Content-Length: 96
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"</script><svg/onload=alert(1)>","photoUrls":[],"tags":[],"status":"laudantium"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=<script>alert('XSS_VULNAPI_TEST')</script>
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:23 GMT
Content-Type: application/json
Content-Length: 103
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":"<script>alert('XSS_VULNAPI_TEST')</script>"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status="><script>alert(1)</script>
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:23 GMT
Content-Type: application/json
Content-Length: 89
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":"><script>alert(1)</script>"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=""><img src=x onerror=alert(1)>
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:23 GMT
Content-Type: application/json
Content-Length: 92
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":""><img src=x onerror=alert(1)>"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_79

6.1

Référence CAPEC: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=</script><svg/onload=alert(1)>
```

Réponse :

```
Status: 200 OK
Date: Thu, 04 Jun 2026 09:03:24 GMT
Content-Type: application/json
Content-Length: 91
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, PUT
Access-Control-Allow-Headers: Content-Type, api_key, Authorization
Access-Control-Expose-Headers: Content-Disposition
Server: Jetty(9.4.53.v20231009)

{"id":45,"name":"minus","photoUrls":[],"tags":[],"status":"</script><svg/onload=alert(1)>"}
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "praesentium"}
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet
```

```
Content-Type: application/json
```

```
{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Sensitive Information in Query String

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_598

6.5

Référence CAPEC: CAPEC-87

OWASP: A04:2025 - Cryptographic Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint accepts a parameter named 'password' in the URL query string. Query strings are logged by reverse proxies, web servers, and browser histories, leading to sensitive data exposure.

Preuve

Parameter 'password' found in GET request.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

No Response

Remédiation

Move sensitive data from the query string to HTTP Headers (e.g., Authorization header) or the request body (e.g., POST request).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 400 instead of 429.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=aut
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/store/order`

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user
Content-Type: application/json

{"data": "culpa"}
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 400 instead of 429.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user/createWithList
Content-Type: application/json

{"data": "veritatis"}
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/user/dolore
Content-Type: application/json

{"data": "reprehenderit"}
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base: CWE: CWE_799

5.3

Référence CAPEC: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/user/dolore
```

Réponse :

No Response

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "praesentium"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "praesentium"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "praesentium"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "praesentium"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
PUT https://petstore3.swagger.io/api/v3/pet
Content-Type: application/json

{"data": "praesentium"}
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=quia
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=quia
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=quia
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=quia
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: `GET https://petstore3.swagger.io/api/v3/pet/findByStatus`

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByStatus?status=quia
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByTags?tags=quod
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/pet/findByTags`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByTags?tags=quod
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByTags?tags=quod
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: `GET https://petstore3.swagger.io/api/v3/pet/findByTags`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByTags?tags=quod
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: `GET https://petstore3.swagger.io/api/v3/pet/findByTags`

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/findByTags?tags=quod
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/30
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/30
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/30
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/30
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/pet/30
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/pet/64
api_key: minima
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/45?name=minus&status=laudantium
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=aut
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=aut
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=aut
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=aut
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
POST https://petstore3.swagger.io/api/v3/pet/35/uploadImage?additionalMetadata=aut
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/store/inventory`

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/inventory
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/inventory
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/inventory
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/store/inventory`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/inventory
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/inventory
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: POST <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: POST <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
POST https://petstore3.swagger.io/api/v3/store/order
Content-Type: application/json

{"data": "repudiandae"}
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/store/order/{orderId}`

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/order/26
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/store/order/{orderId}`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/order/26
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/order/26
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/store/order/{orderId}`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/order/26
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/store/order/26
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/store/order/64
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user
Content-Type: application/json

{"data": "culpa"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user
Content-Type: application/json

{"data": "culpa"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user
Content-Type: application/json

{"data": "culpa"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user
Content-Type: application/json

{"data": "culpa"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
POST https://petstore3.swagger.io/api/v3/user
Content-Type: application/json

{"data": "culpa"}
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user/createWithList
Content-Type: application/json

{"data": "veritatis"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user/createWithList
Content-Type: application/json

{"data": "veritatis"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user/createWithList
Content-Type: application/json

{"data": "veritatis"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
POST https://petstore3.swagger.io/api/v3/user/createWithList
Content-Type: application/json

{"data": "veritatis"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
POST https://petstore3.swagger.io/api/v3/user/createWithList
Content-Type: application/json

{"data": "veritatis"}
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/user/login`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/login?password=dolor&username=harum
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/logout
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/logout
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/logout
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/logout
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/logout
```

Réponse :

```
No Response
```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/vet
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/vet
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/vel
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/vet
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: `GET https://petstore3.swagger.io/api/v3/user/{username}`

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
GET https://petstore3.swagger.io/api/v3/user/vel
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/user/dolore
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/user/dolore
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/user/dolore
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/user/dolore
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: DELETE <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
DELETE https://petstore3.swagger.io/api/v3/user/dolore
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/user/dolore
Content-Type: application/json

{"data": "reprehenderit"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/user/dolore
Content-Type: application/json

{"data": "reprehenderit"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/user/dolore
Content-Type: application/json

{"data": "reprehenderit"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
PUT https://petstore3.swagger.io/api/v3/user/dolore
Content-Type: application/json

{"data": "reprehenderit"}
```

Réponse :

No Response

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_200

3.7

Référence CAPEC: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Requête :

```
PUT https://petstore3.swagger.io/api/v3/user/dolore
Content-Type: application/json

{"data": "reprehenderit"}
```

Réponse :

No Response

Remédiation

Configure your web server to remove or mask the 'Server' header.